Security Foundations Assessment 01

EWB Courses | Assessment 01 | AI Powered Cybersecurity

Name: Kavali Mamatha
Batch : 1

Task A Secure a student account

A1 and A2 Risks controls and limitations

Confidentiality protects information from unauthorised access. Integrity protects information from unauthorised changes. Availability means information and services remain accessible when needed.

Risk	Asset	CIA impact	Control	Limitation
Short password reused across accounts	Email and learning portal	Confidentiality: guessed or leaked credentials may expose messages. Integrity: an intruder may alter submissions.	Use a long, unique password for each account, stored in a password manager.	A password can still be phished; securing recovery options and using MFA remain necessary.
Approving unexpected sign-in prompts	Account access and portal records	Confidentiality and integrity: approval may admit another person to the account.	Deny unexpected prompts and report them. Use phishing-resistant MFA where supported.	Training can be forgotten; stronger MFA may not be supported by the portal.
Postponed device updates	Laptop software and stored files	All three: exploitation may expose, change or encrypt files and interrupt study.	Enable automatic updates and restart promptly to apply them.	Updates do not fix every vulnerability or prevent every unsafe action.
Only one project copy	Project files and coursework	Availability: device failure, theft or accidental deletion may destroy access.	Keep a separate versioned backup and periodically test restoring a file.	A connected or synchronised copy may also lose files; separate protected versions are needed.
Friend uses Mira’s signed-in account	Private files, email and submissions	Confidentiality: private data may be read. Integrity: work may be changed under Mira’s identity.	Create a separate standard user account for the friend; lock Mira’s session.	Separation fails if Mira shares her password or leaves her session unlocked.

Task A Priorities and access concepts

A2 First three actions in priority order

1. Deny unexpected sign-in prompts and report them to official support first, because they may indicate an ongoing attempt to access the account. If a prompt was already approved, ask IT to revoke suspicious sessions immediately.

2. Replace the short reused passwords with long, unique passwords. Secure email first because it can reset the portal password, then secure the portal and review recovery details. This prevents one exposed password from opening both accounts; changing a password may not end existing sessions.

3. Install pending operating-system and application updates through trusted settings, then enable automatic updates. This closes known weaknesses that could undermine account protection. Account misuse comes first because it may already be happening, followed by password exposure and device vulnerabilities.

Next, create a separate versioned project backup, test restoration and give the friend a separate standard user account. These address project loss and misuse of an unlocked session. The scenario identifies risks, but does not establish that an account has been compromised.

A3 Authentication and authorisation

Authentication checks who is signing in. Mira's portal verifies her password and an additional factor before granting access to her account.

Authorisation checks what the signed-in user may do. Mira's student role may let her view her own results and submit assignments, but not edit another student's marks or manage accounts. A teacher may grade submissions. The portal must enforce permissions even after successful authentication.

Task B Analyse a suspicious message

B1 Five warning signs

Relevant evidence	Why it needs scrutiny
“awards@campus-awards.example” “help@personal-awards.example”	The sender differs from the normal campus.example domain, and replies go to another domain. A legitimate external service is possible, but both require independent verification.
“expires in 20 minutes”	The short deadline creates pressure to act before checking the claim.
“enter your college password and OTP”	The message requests credentials and an authentication code through its own link, creating an account-takeover risk.
“Do not contact the college office”	It discourages independent checking, which would help detect impersonation.
“photo of your identity card”	It requests sensitive identity information without establishing an official need or secure process.

B2 Safe verification process

1. Do not open the supplied link, reply, enter credentials or send an identity-card photo. Preserve the original message for the college IT team.

2. Open a previously trusted college portal bookmark, or obtain the scholarship office’s contact from an established college directory or an in-person visit. Do not use contact details from the suspicious message. Ask whether the scholarship notice and verification process are genuine.

3. HTTPS encrypts communication with the domain visited; it does not establish that the domain belongs to the college. A familiar display name can be chosen by an impersonator and therefore also proves little.

B3 Response if credentials and OTP were entered

4. From a trusted device, open the genuine portal and immediately change the affected password. Change it on other accounts where it was reused. Revoke other sessions if possible; otherwise ask official IT to do so urgently. Do not approve further unexpected prompts.

5. Report the exposure to college IT and the scholarship office through verified channels. Provide the original message, time and actions taken, without sharing the password or OTP. Preserve evidence before deleting the message.

6. Review sign-in history, recovery contacts, MFA methods, connected applications and email forwarding rules. Ask IT to remove unauthorised changes, assess activity during any session and monitor for further access or follow-up scams. An expired OTP does not terminate a session already created.

B4 What cannot be established

The text alone cannot establish who actually sent the message. Original headers, mail authentication results and confirmation from the official office would help assess origin; none alone identifies a person conclusively. These are warning signs in fictional evidence, not proof about a real website. [1, 2]

Task C Triage a sign in alert

C1 Four point timeline

All times are IST on 18 October 2026. The addresses are documentation examples.

Time	Observed evidence	Interpretation
09:00–09:01	Password succeeds and MFA is approved from 192.0.2.10, the stated usual classroom egress.	Consistent with normal classroom access; the address alone does not identify the user.
10:14–10:16	Two password failures are followed by a password success from 198.51.100.23.	Could be guessing followed by valid credentials, or someone correcting typing errors. The method of obtaining credentials is unknown.
10:17–10:18	MFA is denied, then approved. The student says they did not sign in after 09:05 and approved around 10:18 to stop repeated requests.	Strongly suggests an approval obtained through prompt fatigue. The excerpt records two MFA outcomes; the total number of prompts is unknown.
10:20	A session is created from 198.51.100.23.	Access was established following approval. The excerpt does not show what the session accessed or changed.

C2 Likely explanation alternatives and checks

Likely explanation: another party obtained or guessed a valid password and induced the student to approve MFA through repeated prompting. The sequence and the student's statement support suspected account compromise, but do not prove password theft or identify an individual.

Alternative explanation: a legitimate device or application retried authentication after a network change, and the student misunderstood its prompt or recalled the timing incorrectly. This is less consistent with the stated lack of sign-in activity, but must be checked.

Check 1: correlate authentication transaction IDs, device identifiers, browser details, MFA delivery records and session records. Compare them with known student devices and authorised VPN or network changes. Check 2: confirm the student's device and application activity around 10:14–10:20 and review the new session's audit trail for accessed files, changes and recovery or MFA enrolments. These checks can distinguish familiar background activity from unrecognised access.

C3 Three prioritised IT actions

1. Preserve the relevant authentication, MFA and session logs and the user statement promptly, recording timezone, collection time and access controls. Preserve available evidence alongside urgent containment; do not delay containment for a complete investigation.
2. Revoke the suspicious session and other active tokens as appropriate, temporarily restrict the account if necessary, reset credentials and verify recovery and MFA settings through the official process.
3. Review downstream activity, reverse unauthorised changes, strengthen MFA where available and monitor the account. Explain that unexpected prompts should be denied and reported.

C4 Incident summary

At 10:16 IST, a password authentication succeeded from 198.51.100.23 after two failures. MFA was denied at 10:17, approved at 10:18, and a session was created at 10:20. The student denies signing in after 09:05 and says they approved a prompt to stop repeated requests. This supports suspected account compromise through MFA fatigue, but the address does not identify a person and password theft is unproven. Treat the case as high priority: preserve authentication evidence while revoking suspicious sessions, then verify device details and examine account activity. [1]

Task D Review an AI security answer

D1 Five corrections to unsafe advice

Unsafe claim or action	Correction and supporting reasoning
The email is safe because it uses HTTPS.	HTTPS protects the connection to the domain, not the legitimacy of the scholarship claim. Task B contains a nonstandard domain, credential request and pressure to avoid the office. Independently verify the message. [1]
The logs prove that the person using the address stole the password.	The logs show password success and a later session, not how credentials were obtained. An IP address can be shared or represent a VPN or proxy; it does not identify a person. State suspected unauthorised access and investigate alternatives. [1]
MFA prevents every account compromise.	MFA reduces risk but is not an absolute guarantee. In Task C the student approved an unexpected prompt, and a session followed. Use stronger methods where supported and deny unsolicited prompts. [1, 2]
Delete the suspicious logs.	Preserve relevant logs with timestamps and controlled access. Deletion removes evidence needed to establish events and impact. Preserve evidence while containing the account, following the authorised IT process. [1]
Send the student’s password to support.	Never send passwords or OTPs to support or include them in AI prompts. Official support should use an approved reset process and investigate logs rather than obtain the student’s secret. Limit incident reports to necessary non-secret evidence. [1, 2]

Task D Corrected advice and references

D2 Better AI analysis prompt

Analyse only the supplied fictional scholarship message, synthetic sign-in logs and user statement. Separate observed facts from interpretations and unknowns. Identify phishing warning signs, build a four-point timeline and give a likely explanation, an alternative and two checks. Do not infer identity from an IP address or claim password theft is proven. Recommend prioritised actions for authorised IT, including evidence preservation and account protection. Never request passwords, OTPs, identity documents or real student data. State uncertainty and connect conclusions to the supplied evidence.

D3 Corrected security advice

Treat the scholarship message as suspicious because it pressures the student, requests a password and OTP, and discourages contacting the college. Verify the claim through an independently obtained official contact or trusted portal. HTTPS alone does not prove legitimacy. If credentials were entered, change the password through the genuine service, revoke active sessions and report the exposure to college IT. Preserve the original message and relevant logs without sharing secrets. The sign-in sequence and the student's statement suggest possible MFA fatigue and unauthorised access, but do not identify the person involved or prove password theft. The authorised IT team should preserve evidence while containing access, review account changes and strengthen authentication. Check AI advice against the evidence and trustworthy guidance before acting.

D4 AI use declaration

OpenAI ChatGPT was used to draft, shorten and format this report. The answers require student review before submission. Only the supplied fictional evidence was used; no live systems were tested.

Two evidence and reference notes

1. The Task C log records a denial at 10:17, an approval at 10:18 and session creation at 10:20. Together with the student's statement, this supports suspected MFA fatigue but does not prove who signed in, how the password was obtained or what was accessed. [1]

2. CISA describes phishing recognition, strong unique passwords, MFA and updates as protective practices. NIST AI 600-1 Section 2.2 explains confabulation, supporting independent checks of confident AI claims. These references support the reasoning; the case-specific conclusions depend on the supplied evidence. [2, 3]

References

[1] EWB Courses. Assessment 01 Security foundations. Issued 18 October 2026. Supplied assessment, Tasks A–D.
[2] CISA. Secure Our World. https://www.cisa.gov/secure-our-world
[3] NIST. Generative Artificial Intelligence Profile. NIST AI 600-1, July 2024, Section 2.2 Confabulation. https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf